Risk Assessment Register

Asset ID	Asset Name	Threat/Vulnerability	Existing Controls	Likelihood (1-3)	Impact (1-3)
AST-01	Production Database (AWS RDS)	**Threat:** Ransomware or unauthorised data access. **Vulnerability:** Weak or missing Multi-Factor Authentication (MFA) on AWS root-admin accounts.	**Traditional credential: SQL server authentication.** Username and password to access company's database.	3	3
AST-02	Remote Employee Laptops	**Threat:** Laptop theft or loss exposing patient data. **Vulnerability:** Local hard drives are not encrypted, and devices lack remote-wipe credentials.	**Kensington lock**	2	3
AST-03	Customer Support Portal	**Threat:** Phishing or social engineering of support staff to gain access to customer clinic accounts. **Vulnerability:** Support staff have never received formal security awareness training.	**Inbound Filtering:** SMTP proxy.	3	2
AST-04	Application installation	**Threat:** Malware spreads to employees' devices and spreading within the network. **Vulnerability:** Installing unauthorised software (Shadow IT) on employees' devices could cause adware to be installed without notice causing a backdoor for attackers to exploit.	**User Account Control**	2	3

Inherent Risk (L x I	Risk Treatment strategy	Mitigation Plan	Mitigated Risk Score
3 x 3 = **9 (High)**	**Reduce/Mitigate**	Enforce mandatory hardware/app-based MFA for all AWS IAM accounts. Restrict database access to specific company IP addresses via security groups.	1 x 3 = **3 (Low)**
2 x 3 = **6 (Medium)**	**Reduce/Mitigate**	Deploy a Mobile Device Management (MDM) solution to enforce FileVault (Mac) / BitLocker (Windows) full-disk encryption and remote wipe.	1 x 3 = **3 (Low)**
3 x 2 = **6 (Medium)**	**Reduce/Mitigate**	Implement a mandatory onboarding and annual security awareness training program within 7 business days and monthly simulated phishing campaigns.	1 x 2 = **2 (Low)**
2 x 3 = 6 **(Medium)**	**Reduce/Mitigate**	Deploy Mobile Device Management (MDM), define an AllowList, use the Enforce Least-Privilege Access and Deploy Application Control Policies (Microsoft AppLocker) to ensure that only employees can access and install authorised software preventing malware from spreading within the network.	1 x 2 = **2 (Low)**